Lösch- und Aufbewahrungskonzept „Zeitly" – STEINERfood GmbH

Version 1.0 · Stand [Datum] · Verantwortlicher: STEINERfood GmbH · Auftragsverarbeiter: MALELU AI – Peter Vitzthum

1. Zweck und Geltungsbereich

Dieses Konzept legt fest, wie lange die in Zeitly verarbeiteten personenbezogenen Daten aufbewahrt werden, auf welcher Rechtsgrundlage, welches Ereignis die Frist auslöst und wie die Löschung technisch und organisatorisch umgesetzt wird (Art. 5 Abs 1 lit e, Art. 17, Art. 25 DSGVO). Es gilt für alle Daten des Mandanten STEINERfood GmbH in Zeitly einschließlich Backups und Protokollen.

Grundsatz: Arbeitszeitaufzeichnungen sind **Abrechnungsgrundlagen** und als solche **7 Jahre** aufzubewahren; alles, was nicht Abrechnungsgrundlage ist (Anmeldecodes, Logins, Backups), wird so kurz wie möglich gespeichert.

2. Fristenübersicht

Nr.	Datenart	Aufbewahrungsfrist	Rechtsgrundlage der Frist	Fristauslöser (Trigger)	Umsetzung in Zeitly	Art
1	Einmal-Anmeldecodes	24 Stunden (bzw. sofort nach Verwendung)	Datenminimierung Art. 5 Abs 1 lit c, e DSGVO	Erzeugung des Codes	Automatischer Job löscht abgelaufene/verwendete Codes stündlich	automatisiert
2	Anmeldeprotokolle (Zeitpunkt, IP, Browser)	90 Tage	Art. 6 Abs 1 lit f DSGVO (IT-Sicherheit); Orientierung an Empfehlungen zur Log-Aufbewahrung	Zeitpunkt der Anmeldung	Täglicher Job löscht Einträge älter als 90 Tage	automatisiert
3	Technische Server-/Fehlerlogs	90 Tage	Art. 6 Abs 1 lit f DSGVO	Zeitpunkt des Log-Eintrags	Log-Rotation am Server (logrotate) und beim Hosting-Anbieter	automatisiert
4	Datenbank-Backups	30 Tage rollierend	Art. 32 Abs 1 lit c DSGVO (Wiederherstellbarkeit)	Erstellung des Backups	Backup-Richtlinie des Datenbankanbieters; ältere Sicherungen werden automatisch überschrieben	automatisiert
5	Sitzungen (Login-Sessions)	[z. B. 30 Tage] Inaktivität	Art. 32 DSGVO	letzte Aktivität	Ablaufdatum im Session-Token; Admin kann alle Sitzungen eines Nutzers beenden	automatisiert
6	Arbeitszeitbuchungen (Beginn, Ende, Pausen, Dauer, Art, Arbeitsort-Kategorie, Projekt, Notizen)	7 Jahre ab Ende des Kalenderjahres, in das die Buchung fällt	§ 132 Abs 1 BAO (Bücher, Aufzeichnungen und Belege 7 Jahre); § 26 AZG (Aufzeichnungen müssen für die Kontrolle verfügbar sein; Verjährung § 1486 ABGB 3 Jahre, Hemmung § 26 Abs 9 AZG); ASVG-Beitragsgrundlagen; § 76 EStG Lohnkonto	Ende des Kalenderjahres; bei anhängigem Verfahren (Behörde, Gericht) Verlängerung bis zum rechtskräftigen Abschluss (§ 132 Abs 1 BAO letzter Satz)	Jährlicher Löschlauf (Jänner) durch Admin: Anonymisierung aller Buchungen mit Datum vor dem 1.1. des Jahres minus 7; Zeitly zeigt eine Vorschau mit Anzahl der Datensätze; Sperre für Datensätze mit Vermerk „Verfahren anhängig"	manuell / jährlich (Vorschlag automatisiert)
7	Abwesenheiten (Urlaub, ZA, Krankenstand,	7 Jahre ab Ende des Kalenderjahres	wie Nr. 6; UrlG (Urlaubsaufzeichnung § 8 UrlG),	Ende des Kalenderjahres	mit Nr. 6 im Löschlauf	manuell / jährlich

Nr.	Datenart	Aufbewahrungsfrist	Rechtsgrundlage der Frist	Fristauslöser (Trigger)	Umsetzung in Zeitly	Art
	Pflegefreistellung, Sonderurlaub, Fortbildung, unbezahlt)		EFZG			
8	Monatsabschluss-Bestätigungen (Zeitstempel, IP)	7 Jahre (mit der Monatsaufzeichnung)	§ 26 Abs 2 AZG (Kontrollpflicht des Arbeitgebers bei übertragener Aufzeichnung – Nachweis)	Ende des Kalenderjahres	mit Nr. 6 im Löschlauf	manuell / jährlich
9	Audit-Log (Änderungsprotokoll zu Buchungen, Abwesenheiten, Stamm-/Vertragsdaten)	solange die zugehörigen Daten (max. 7 Jahre)	Nachweis der Integrität der Aufzeichnungen (§ 26 AZG, Art. 5 Abs 2 DSGVO)	Löschung des zugehörigen Datensatzes	Audit-Einträge werden gemeinsam mit dem referenzierten Datensatz anonymisiert/gelöscht	mit Nr. 6
10	Vertragsdaten (Wochenstunden, Arbeitstage, Gleitzeit, Urlaubsanspruch, Eintrittsdatum, Salden-Historie)	7 Jahre nach Ende des Kalenderjahres des Austritts	§ 132 BAO; § 76 EStG; Nachweis in arbeitsrechtlichen Streitigkeiten	Austritt des Mitarbeiters	mit Löschlauf nach Ablauf der Frist	manuell / jährlich
11	Stammdaten (Name, dienstliche E-Mail, Personalnummer, Rolle)	Sperre sofort bei Austritt; Löschung/Anonymisierung mit Ablauf der letzten Frist der zugehörigen Daten (Nr. 6–10)	Art. 5 Abs 1 lit e DSGVO; Aufbewahrungspflichten als Rechtfertigung der Weiterspeicherung (Art. 17 Abs 3 lit b)	Austritt (Sperre); Ablauf 7 Jahre (Löschung)	Status „inaktiv" am Austrittstag → kein Login, keine E-Mails; im Löschlauf wird der Personendatensatz durch ein Pseudonym („Ehem. MA #ID") ersetzt, E-Mail gelöscht	Sperre manuell (Offboarding), Löschung jährlich
12	Exporte (CSV/PDF), die Nutzer herunterladen oder per E-Mail erhalten	Export-Datei auf dem Server: 24 Stunden; beim Empfänger: in dessen Verantwortung	Art. 5 Abs 1 lit c DSGVO	Erzeugung des Exports	Temporäre Dateien werden nach 24 h automatisch gelöscht; E-Mail-Zustellprotokoll beim Versanddienst gemäß dessen Richtlinie [prüfen: Resend Standard 30 Tage?]	automatisiert
13	Daten des gesamten Mandanten bei Vertragsende	Export 30 Tage, danach vollständige Löschung; Backups nach weiteren max. 30 Tagen überschrieben	§ 10 AVV; Art. 28 Abs 3 lit g DSGVO	Beendigung des Hauptvertrags	Admin löst Gesamtexport aus; Auftragsverarbeiter löscht nach 30 Tagen und bestätigt schriftlich	manuell nach Vertragsende

Hinweis zur 7-Jahres-Frist: Die Frist läuft ab Ende des Kalenderjahres, auf das sich die Aufzeichnung bezieht (§ 132 Abs 1 BAO). Beispiel: Buchungen aus 2026 dürfen frühestens am 1.1.2034 gelöscht werden. Bei anhängigen Abgaben-, Sozialversicherungs-, Verwaltungsstraf- oder Gerichtsverfahren, für die die Aufzeichnungen von Bedeutung sind, ist die Löschung bis zum Abschluss auszusetzen.

3. Löschmethoden

Methode	Beschreibung	Anwendung
Physische Löschung	Datensatz wird aus der Datenbank entfernt (DELETE); Backups überschreiben sich nach 30 Tagen	Anmeldecodes, Anmeldeprotokolle, Logs, Sessions, Export-Dateien, Gesamtmandant bei Vertragsende
Anonymisierung	Personenbezug wird unwiederbringlich entfernt: Name → „Ehem. MA #ID", E-Mail und Personalnummer gelöscht, Notizen gelöscht; Buchungsdaten bleiben ohne Personenbezug für Statistiken (z. B. Gesamtstunden je Projekt) erhalten	Buchungen und Abwesenheiten nach 7 Jahren, wenn der Verantwortliche aggregierte Projektstatistik behalten möchte; sonst physische Löschung
Sperre	Konto deaktiviert, kein Login, keine Benachrichtigungen; Daten für berechtigte Rollen weiterhin lesbar; keine Änderungen mehr möglich außer durch Admin mit Protokoll	ausgeschiedene Mitarbeiter während der Aufbewahrungsfrist (Art. 18 DSGVO „Einschränkung der Verarbeitung")

4. Offboarding-Prozess (Austritt eines Mitarbeiters)

Schritt	Wann	Wer	Was
1	Vor dem letzten Arbeitstag	Vorgesetzte / Mitarbeiter	Offene Buchungen des laufenden Monats vervollständigen; Resturlaub und Zeitsaldo prüfen (Grundlage für Urlaubsersatzleistung § 10 UrlG und Zeitausgleichsabgeltung)
2	Letzter Arbeitstag	Mitarbeiter	Letzten Monatsabschluss bestätigen; eigenen Export (PDF/CSV aller Buchungen) herunterladen – Hinweis in Zeitly beim Setzen des Austrittsdatums
3	Letzter Arbeitstag (spätestens Folgetag)	Admin	Austrittsdatum in Zeitly setzen → Konto wird automatisch zum Austrittsdatum 23:59 gesperrt (kein Login, keine E-Mails); Rolle „Vorgesetzte"/„Admin" wird entzogen, Teamzuordnungen werden aufgelöst
4	Innerhalb von 14 Tagen	Admin / Lohnverrechnung	Abschlussexport der Person für Lohnverrechnung (Endabrechnung) und Personalakt erstellen
5	Laufend	–	Daten bleiben gesperrt gespeichert (Aufbewahrungsfrist); Zugriff nur Admin, Lohnverrechnung
6	Jänner des Jahres nach Ablauf der 7 Jahre	Admin	Jährlicher Löschlauf (siehe Punkt 5) anonymisiert/löscht die Person und ihre Daten
7	Auf Verlangen	Admin	Auskunft (Art. 15) oder Übermittlung der Aufzeichnungen (§ 26 Abs 8 AZG) auch nach Austritt: Export aus gesperrtem Konto möglich

Sonderfall Löschersuchen (Art. 17) eines ausgeschiedenen Mitarbeiters: Es ist zu antworten, dass die Arbeitszeitaufzeichnungen aufgrund gesetzlicher Aufbewahrungspflichten (Art. 17 Abs 3 lit b DSGVO iVm § 132 BAO) bis [Datum] aufbewahrt werden müssen; nicht aufbewahrungspflichtige Daten (z. B. Notizen, Anmeldeprotokolle) werden sofort gelöscht.

5. Jährlicher Löschlauf (Verantwortlicher)

1. **Termin:** jeweils im Jänner, Verantwortung: Admin STEINERfood (Vertretung: [Name]). Zeitly erinnert per E-Mail.
2. **Vorschau:** Zeitly zeigt unter „Einstellungen → Datenschutz → Löschlauf" alle Datensätze mit Datum vor dem 1.1. des laufenden Jahres minus 7 Jahre, gruppiert nach Person, inklusive Anzahl.
3. **Ausnahmen prüfen:** Personen/Zeiträume mit Vermerk „Verfahren anhängig" (vom Admin setzbar) werden ausgenommen und beim nächsten Lauf erneut angezeigt.
4. **Durchführung:** Admin wählt „Anonymisieren" oder „Löschen" und bestätigt mit Einmalcode. Der Vorgang wird im Audit-Log mit Anzahl der betroffenen Datensätze (ohne Personenbezug) protokolliert.
5. **Nachweis:** Zeitly erzeugt ein Löschprotokoll (PDF) für die Datenschutzdokumentation des Verantwortlichen.
6. **Backups:** Gelöschte Daten verschwinden spätestens 30 Tage nach dem Lauf aus allen Sicherungen. Eine Wiederherstellung aus einem Backup innerhalb dieser Frist setzt den Löschlauf für die betroffenen Datensätze erneut voraus (automatischer Hinweis an den Admin nach einem Restore).

6. Pflichten der Beteiligten

Beteiligter	Pflicht
STEINERfood GmbH (Verantwortlicher)	Austrittsdaten rechtzeitig setzen; jährlichen Löschlauf durchführen; Verfahrensvermerke pflegen; eigene Exporte (Personalakt, Lohnverrechnung) nach eigenem Löschkonzept behandeln; Löschersuchen beantworten
MALELU AI (Auftragsverarbeiter)	Automatisierte Löschjobs betreiben und überwachen; Backup-Aufbewahrung von 30 Tagen sicherstellen; Löschfunktionen bereitstellen; auf Weisung löschen; bei Vertragsende Export und Löschbestätigung; Änderungen an Fristen nur nach Weisung
Vorgesetzte	Keine Kopien von Teamauswertungen außerhalb von Zeitly aufbewahren, die über den Zweck hinausgehen; lokale Exporte nach Verwendung löschen
Lohnverrechnung	Exporte nach Übernahme in das Lohnprogramm gemäß eigener Aufbewahrungsregel (7 Jahre) ablegen; keine zusätzlichen Kopien

7. Überprüfung

Dieses Konzept wird jährlich (gemeinsam mit dem Löschlauf) sowie bei Änderungen der Rechtslage, der Verarbeitungszwecke oder der technischen Umsetzung überprüft. Letzte Überprüfung: [Datum], durch [Name].

Muster, keine Rechtsberatung – vor Verwendung durch Rechtsberatung prüfen lassen.